

Self-assessment of the subsidiary in CISO Assistant

✓ The blank assessment from session 3 meets reality

Systematic

Independent

Documented

the adjective self-assessment lacks

It prepares and clears the ground for the audit, it does not replace it

Session objectives

By the end of this lab, the compliance assessment "MERIDIAN-SUBSIDIARY - ISO/IEC 27001:2022 - initial assessment", created in session 3 and left blank, carries the completed statuses of a subset of twelve requirements for the subsidiary under review, each justified by a piece of evidence or by the admission that there is none; the working sheet carries the per-theme summary and the raw list of deviations that will feed the audit report of the next sequence. What is learned here:

- **Conduct** a toolled security self-assessment: frame, assess requirement by requirement, summarize

- **Apply** the morning lecture's discipline of evidence to one's own work, which is harder than it looks
- **Distinguish** what the self-assessment allows, preparing and roughing out, from what it does not replace, the independent audit
- **Convert** assessment statuses into a maturity reading usable by senior management

Prerequisites

- The compliance assessment created in the session 3 lab, attached to the domain of the subsidiary under review built in session 2: this entire lab fills it in, nothing gets recreated.
- The findings from midday's tutorial, those of the subsidiary under review, and their grading.
- The session 2 mapping: it is what supplies the evidence for several statuses.
- The information security maturity grid seen in session 1, reused here without being redefined.

✓ The self-assessment: a state of play without complacency, or nothing

One new notion before getting hands-on, the only one of the afternoon. The problem it solves: an independent audit costs time and money, and a group that waited for the auditor to discover its own state would spend the audit learning what it could have known on its own. The **"security self-assessment"** is the compliance assessment an organization conducts on itself, with the same criteria and the same discipline of evidence as an audit, but without the independence. The idea is nothing exotic: ANSSI's hygiene guide, met in session 3, ships its own tracking tool and invites every organization to use it: « Commencez par établir un état des lieux pour chacune des règles grâce à l'outil de suivi qui se trouve en annexe de ce document. » (start by drawing up a state of play for each of the rules using the tracking tool annexed to this document.) The mechanics, which the GRC tool industrializes: go through the framework requirement by requirement, give each one a status, back each status with a piece of evidence. The limit, settled once and for all this morning: without independence, no audit; the self-assessment prepares, roughs out, orients, but whoever evaluates their own work structurally tends to confuse "planned" and "done". This whole lab is an exercise in severity towards oneself.

The module's status scale, the one that applies here:

Status	Meaning	What it requires
Covered	The requirement is satisfied over the assessed scope	A verifiable piece of evidence, not a declaration
Partial	The requirement is satisfied over part of the scope, or partially	The evidence of what exists AND the description of what is missing
Not covered	The requirement is not satisfied	The finding, as worded this morning
Not assessed	No evidence available either way	The explicit admission, which is worth more than an estimate
Not applicable	The requirement is moot on this scope	A written justification, never a comfort

The tool will offer its own status labels; whatever they are in the version used, map them to this scale and note the mapping on the sheet. The statuses are entered in the tool; the justifications and the evidence are recorded on the working sheet, which will accompany the report.

💡 The question that saves a self-assessment, to ask before every "covered": what evidence would an independent auditor accept tomorrow morning? If the answer is "the team's word", the honest status is "not assessed", and writing it is not a failure: it is the only information that tomorrow's audit will not be able to hold against the group.



Exercise 1: frame the self-assessment (10 minutes)

A state of play without framing becomes a stroll. This lab's fits in three lines, like an audit.

Expected output: the framing box, at the top of the working sheet.

1. **Delimit** the scope: the subsidiary under review, with its systems mapped in session 2.
2. **Set** the criteria: the twelve requirements of the exercise 2 subset, extracted from the ISO/IEC 27001:2022 framework imported in session 3, supplemented by the applicable framework PSSI directives.
3. **Fix** the rule of evidence: no requirement declared "covered" without named evidence; doubt is declared "not assessed".

Exercise 2: assess twelve requirements, evidence in hand (35 minutes)

The day's subset, chosen because it crosses the audit programme's findings and the subsidiary's baseline. The titles are those displayed by the tool's library.

Ref.	Requirement (library title)
A.5.9	Inventory of information and other associated assets
A.5.15	Access control
A.5.16	Identity management
A.5.17	Authentication information
A.5.19	Information security in supplier relationships
A.5.22	Monitoring, review and change management of supplier services
A.6.3	Information security awareness, education and training
A.8.2	Privileged access rights
A.8.5	Secure authentication
A.8.8	Management of technical vulnerabilities
A.8.15	Logging
A.8.22	Segregation of networks

The field file: the pack of the subsidiary under review, its mapping and its security needs (session 2), its findings graded at midday and the framework PSSI directives (codified in session 1). The framework policy directives as codified in session 1 (ACC-01 to COR-01) are authoritative for this exercise, whatever wording the group adopted: ACC-01, multi-factor authentication for all remote access and all administration privileges; ACC-02, quarterly review of access privileges on business databases; INC-01, notification of any major incident to the Group CISO within 2 hours; JRN-01, log collection toward the group's centralized SOC; COR-01, every critical patch applied within 14 days.

1. **Find** in the compliance assessment the twelve requirements of the table, by their reference or their title.
2. **Fill in** the status of each one according to the module's scale, in the tool.
3. **Justify** each status on the sheet: the named evidence, or the cited finding, or the admission "no evidence available".
4. **Respect** the golden rule: at least one owned "not assessed" is worth more than twelve declarative "covered"; if there is none, reread the sheet with the question from the box.

Validation criteria, to check before calling the instructor: the twelve requirements carry a status in the tool; every line of the sheet carries a justification; the findings of the subsidiary under review graded at midday show up in the "not covered" statuses; no object created in session 2 or 3 has been recreated or renamed.

Exercise 3: carry the action plan into the tool (15 minutes)

Take the two most serious findings of the subsidiary under review: the most serious of those this midday's tutorial devotes to it, and one finding from its subsidiary pack (section 5) that the tutorial's table does not take up.

Expected output: four applied controls in the tool, two per finding, each attached to the requirement in deviation.

1. **Create** for each finding the correction, as an applied control attached to the requirement assessed in exercise 2: the gesture that makes the established deviation disappear, with its owner and its deadline.
2. **Create** for each finding the corrective action, a second applied control: the gesture that treats the cause and prevents the return, with its owner and its deadline.
3. **Check** each control against the guide's SMART method: specific, measurable, achievable and realistic, defined in time; reword whatever fails the test (hint: "raise team awareness" fails M and T).

Exercise 4: summarize and read the maturity (15 minutes)

Twelve statuses do not speak for themselves; senior management reads trends.

Expected output: the summary at the bottom of the sheet.

1. **Count** the statuses per theme of the framework: organizational controls (the A.5s), people controls (A.6), technological controls (the A.8s), distinguishing covered, partial, not covered, not assessed.
2. **Formulate** in two sentences the subsidiary's maturity reading, in the sense of the information security maturity grid seen in session 1: where is the subsidiary tooled up, where does it live on declarations, where is it blind?
3. **Spot** the bias of one's own assessment: identify the least certain status and write why (hint: look for the one where the evidence is an intention, a project or a directive, not an observable fact).

Exercise 5: extract the material for the report (10 minutes)

The next sequence writes the group's initial audit report; this lab supplies its raw material.

1. **List** on the sheet, separately, all the “not covered” and “partial” statuses, with for each one the requirement, the associated finding if it exists, and the grading retained at midday.
2. **Add** the “not assessed” in a separate list headed “blind spots”: an honest report distinguishes what is in deviation from what is unknown.
3. **Check** that the list contains everything the tutorial graded for the subsidiary under review: a report that loses findings along the way manufactures false assurance.



Answer keys and assessment criteria – cliquer pour révéler